Contents

ms-autenticacion — Justificación del servicio y cobertura de requisitos **1**
1. Misión del servicio . . . 1
2. Requisitos funcionales que cubre . . . 1
3. Requisitos no funcionales que cubre . . . 1
4. Requisitos de seguridad que cubre (mapeo STRIDE) . . . 2
5. Stack tecnológico y por qué cada tecnología . . . 3
6. Delimitación: qué NO hace ms-autenticacion (IE9/IE10) . . . 3
7. Diagramas que respaldan esta justificación . . . 4

ms-autenticacion — Justificación del servicio y cobertura de requisitos

Caso caso04 — **NovaBank** (Banca digital / fintech) · EP01 JVY0101

Este documento justifica la existencia de **ms-autenticacion** como microservicio independiente: qué requisitos del negocio cubre (funcionales, no funcionales y de seguridad), por qué está delimitado así (SRP), y qué tecnología AWS se usa para cada responsabilidad y **por qué**. Los diagramas que respaldan esta justificación están en `docs/diagramas/`.

---

1. Misión del servicio

ms-autenticacion registra y autentica a los usuarios del sistema, administra sus roles y perfiles, y entrega los tokens de identidad (JWT) que el resto de los servicios consume para autorizar cada operación del caso caso04 (NovaBank).

> Concentra TODO el riesgo de identidad del caso: si este servicio falla o se filtra, ningún otro puede operar con seguridad. Por eso se aísla con su propia base de datos y sus propias políticas de acceso.

---

2. Requisitos funcionales que cubre

RF	Requisito (de `00_PresentacionEmpresa.md`)	Qué hace ms-autenticacion al respecto	Evidencia
RF-01	Registro y autenticación robusta del cliente (incluye 2FA y biometría)	Registra y autentica usuarios, gestiona roles y perfiles, y emite los JWT que autorizan las llamadas del resto del sistema	diagrama de secuencia (registro y login)

Por qué estos RF justifican un servicio aparte: Concentra TODO el riesgo de identidad del caso: si este servicio falla o se filtra, ningún otro puede operar con seguridad. Por eso se aísla con su propia base de datos y sus propias políticas de acceso.

---

3. Requisitos no funcionales que cubre

RNF	Criterio	Cómo lo cumple ms-autenticacion	Decisión técnica
RNF-02 (Seguridad)	Cifrado de datos en tránsito y reposo, 2FA, control de acceso por rol, tokenización de tarjetas	JWT por rol, cifrado en tránsito (TLS) y reposo (KMS), auditoría de acciones	Cognito + KMS + Secrets Manager + CloudTrail
RNF-01 (Disponibilidad)	99,99 % de disponibilidad en servicios transaccionales; cero cierres por mantenimiento	Aislamiento por eventos: este servicio sigue operando aunque fallen los vecinos	Comunicación asíncrona (SQS/EventBridge) + multi-AZ
RNF-05 (Mantenibilidad)	Aislar el motor de pagos para actualizarlo sin tocar la banca transaccional	Despliegue independiente (blue/green) sin coordinar con otros dominios	Pipeline CI/CD propio + bajo acoplamiento solo por API/eventos

Justificación SRP (IE9): ms-autenticacion tiene **una sola razón de cambio**: las reglas de identidad: nuevos roles, MFA, login social y normativa de protección de datos personales. Si mañana cambia esa regla, **ningún otro servicio se modifica**.

---

4. Requisitos de seguridad que cubre (mapeo STRIDE)

Amenaza	Escenario en este servicio	Contramedida
Spoofing	Alguien suplanta a un usuario legítimo	Autenticación centralizada (Cognito): contraseñas hasheadas, MFA y JWT firmados; ningún otro servicio valida credenciales
Tampering	Alterar el perfil o los roles en tránsito	TLS 1.2+ en todo el canal y validación del JWT en API Gateway (firma verificada, no confiable del cliente)
Repudiation	Negar un cambio de perfil o rol	CloudTrail + logs de auditoría inmutables de toda operación de identidad
Information disclosure	Fuga de datos personales	Cifrado at-rest con KMS, acceso solo por rol, y nunca credenciales ni tokens en logs
Denial of service	Ataque de fuerza bruta al login	Throttling por IP/token en API Gateway y bloqueo tras reintentos fallidos
Elevation of privilege	Un usuario se autoasigna rol administrador	Roles verificados solo en este servicio mediante claims firmados; autorización por recurso en cada endpoint

---

5. Stack tecnológico y por qué cada tecnología

5.1 Stack de la aplicación

Tecnología	Para qué se usa en ms-autenticacion
Java 21 + Spring Boot 3.3	Framework estándar de la asignatura: implementa la API REST, la lógica de negocio y el acceso a datos del servicio
Spring Data JPA	Persistencia de las entidades del dominio en la base de datos propia (repositorios por entidad)
Bean Validation	Validación de los payloads de entrada antes de procesar (jakarta.validation)
springdoc-openapi	Documentación viva del contrato REST (Swagger UI / ReDoc) para consumidores y equipo
Docker + Docker Compose	Empaquetado reproducible; la misma imagen corre en local y en ECS Fargate
JUnit 5 + Mockito + MockMvc	Pruebas unitarias y de contrato HTTP (cobertura 100 % LINE con JaCoCo)
Cucumber (BDD)	Escenarios en español alineados a los endpoints, ejecutados contra el servidor real

5.2 Stack AWS y justificación de cada servicio

Servicio AWS	Rol en ms-autenticacion	Por qué se eligió
Amazon Cognito	Autenticación de usuarios y emisión de JWT por rol	Servicio managed de identidad: hash de contraseñas, MFA y pools por rol sin construir seguridad a mano (RNF de seguridad)
Amazon Aurora Serverless	BD propia del dominio: usuarios, roles y perfiles	SQL transaccional multi-AZ con cifrado; escala a cero fuera de horas punta
AWS KMS	Cifrado at-rest de los datos personales	Cumplimiento del requisito de protección de datos personales del caso
AWS Secrets Manager	Credencial de la BD con rotación automática	Nada de secretos en código ni en variables (STRIDE-E)
AWS IAM (task role)	Permisos mínimos de la tarea	La tarea solo accede a SUS recursos de identidad
CloudWatch + X-Ray	Métricas, logs, alarmas y trazas del login/registro	Punto de monitoreo del flujo crítico (IE8)

5.3 Patrones aplicados (IE5)

Patrón	Dónde
API Gateway	Entrada única con validación de JWT y throttling
Service Registry (Cloud Map)	Descubrimiento interno de instancias
Publish/Subscribe	Publica eventos de usuario para los demás servicios (EventBridge)

---

6. Delimitación: qué NO hace ms-autenticacion (IE9/IE10)

No hace	Lo hace	Por qué
cuentas	ms-cuentas	razones de cambio distintas: el catálogo consulta y publica; las operaciones de negocio las orquesta el servicio transaccional
transferencias	ms-transferencias	razones de cambio distintas: la operación se orquesta aquí, pero cada colaborador es autónomo
préstamos	ms-prestamos	razones de cambio distintas: el seguimiento vive aquí, pero la operación que lo origina vive en el servicio central
anti-fraude	ms-antifraude	razones de cambio distintas: los reportes viven aquí, pero los datos los generan los servicios operacionales
notificaciones	ms-notificaciones	razones de cambio distintas: la entrega de mensajes vive aquí, pero el contenido lo definen los productores

---

7. Diagramas que respaldan esta justificación

```
docs/diagramas/
├── c4/
│   ├── C4-1-Contexto     el servicio, sus actores y sus vecinos
│   ├── C4-2-Contenedor   la API, la BD propia y los componentes del dominio
│   └── C4-3-Componentes  validador/service, clientes, publicador, repos
├── secuencia/
│   └── Secuencia-Credencial   registro y login (emisión de JWT)
└── infraestructura/
    └── Infra-AWS         despliegue solo de este servicio, con iconos oficiales AWS
```